



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Tareas de Análisis de Riesgos y Modelado de Amenazas

Duración de la presentación: 10-15 minutos por grupo

Objetivo: Aplicar metodologías de análisis de riesgos y threat modeling a escenarios reales. Fomentar la propuesta de trabajo de los estudiantes y el intercambio con el docente.

Metodologías sugeridas: STRIDE, DREAD, MITRE ATT&CK, NIST, ISO 27001

Proceso de Inscripción

Cada grupo debe seleccionar un tema y enviar un correo a apastorini@gmail.com

Asunto: Tarea 2 ISI 2026

Copia a: todos los integrantes

Contenido: Tres escenarios, ordenados por preferencia.

Cronograma

Fecha	Actividad
Mayo (fechas por definir)	Monitoreo en clase - avances, dudas y discusión de opciones con el docente
26 y 28 de mayo	Primera instancia de presentación
16 y 18 de junio	Segunda instancia (solo si el docente lo considera necesario)

Criterio de evaluación: Si el trabajo cumple con los requisitos de entrega en la primera instancia, se aprueba la tarea. En caso contrario, el grupo tendrá la posibilidad de una nueva instancia en junio.



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Estructura Git Recomendada

Todo el material generado debe almacenarse en un repositorio Git **público**. Se sugiere la siguiente estructura de carpetas:

```
mi-grupo-riesgos/  
├── README.md # Descripción del grupo y  
escenario elegido  
├── prompts/ # (Obligatorio si usan IA) Prompts  
utilizados  
│   ├── 01-inventario-activos.txt  
│   ├── 02-stripe-analysis.txt  
│   └── 00-memory-bank.md # Archivo de contexto para la IA  
(ver sección IA)  
├── docs/  
│   ├── 01-inventario-activos.md  
│   ├── 02-arquitectura-trust-boundaries.md  
│   ├── 03-analisis-stride.md  
│   ├── 04-priorizacion-dread.md  
│   ├── 05-mapa-attack.md  
│   ├── 06-plan-mitigacion.md  
│   └── 07-riesgos-residuales.md  
├── diagrams/  
│   ├── arquitectura.drawio  
│   ├── arquitectura.png  
│   └── attack-flow.png  
├── templates/ # Plantillas utilizadas (copias  
locales)  
│   └── Plantilla_Analisis_Riesgos.md  
├── tools/  
│   ├── threat-model.xml # Exportado desde OWASP Threat  
Dragon / MS TMT  
│   ├── risk-matrix.xlsx # Matriz de riesgos (si usa Excel)  
└── references/  
    └── NIST-SP-800-30.pdf # Normativas descargadas
```

Nota: Revisar el archivo `Recursos/Plantilla_Analisis_Riesgos.md` para el formato de documentación.



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Uso de Inteligencia Artificial (Política Obligatoria)

Si el grupo decide utilizar herramientas de IA (Copilot, ChatGPT, Claude, Cursor, etc.), **debe cumplir con los siguientes requisitos:**

1. Registro de Prompts

Todos los prompts utilizados deben almacenarse en la carpeta `prompts/` del repositorio.

- Formato sugerido: `01-description.txt` o `01-description.md`
- Deben incluir: fecha, herramienta utilizada y el texto exacto del prompt.

2. Memory Bank (Enfoque Sugerido)

Para dar contexto a la IA y obtener mejores resultados, el grupo debe crear un archivo `prompts/00-memory-bank.md`. Este archivo le indica a la IA qué archivos son necesarios para entender el proyecto.

Ejemplo de ``00-memory-bank.md``:

```
# Memory Bank - Contexto para IA

## Archivos de contexto necesarios:
- `docs/01-inventario-activos.md` - Lista de activos críticos del sistema bancario
- `diagrams/arquitectura.md` - Diagrama de flujo de datos y trust boundaries
- `templates/Plantilla_Analisis_Riesgos.md` - Formato de salida requerido

## Escenario:
Sistema de Banking Digital (Escenario 1).
Las amenazas deben analizarse bajo la metodología STRIDE aplicada a la arquitectura definida en `diagrams/`.
```

3. Declaración de Herramientas

En el `README.md` del repositorio, incluir una sección:

```
## Herramientas de IA utilizadas
- ChatGPT (GPT-4o) - Para generación de borrador de amenazas STRIDE
```



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Cursor - Asistencia en redacción de controles NIST

Plantillas y Documentación Requerida

Enlaces a Plantillas Oficiales:

Recurso	Enlace
Plantilla Local (Curso)	Plantilla_Analisis_Riesgos.docx
Agesic - Matriz de Riesgos (Excel)	Descargar desde Agesic
NIST SP 800-30 Rev. 1	PDF Nacional (NIST)
NIST SP 800-53 Rev. 5 (Controles)	Controles de Seguridad
NIST SP 800-66 (Guía HIPAA)	Seguridad en Salud

Escenarios Disponibles

Escenario 1: Sistema de Banking Digital

Asignado: Mauro Mascheroni, Ximena Gonzalez

Contexto:

Una fintech está desarrollando una aplicación móvil de banca que permite a usuarios:

- Consultar saldo y movimientos
- Transferencias entre cuentas



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Pagos de servicios
- Préstamos online
- Inversión en fondos

Alcance del análisis:

- App móvil (iOS/Android)
- API Backend (REST)
- Base de datos PostgreSQL
- Integración con pasarela de pagos
- Notificaciones push

Plantillas y Enlaces de Ayuda:

- **STRIDE:** [OWASP Threat Dragon](#) | [Microsoft TMT](#)
- **Riesgos Financieros:** [OWASP Top 10 for Financial](#)
- **Controles:** [NIST SP 800-53 \(Familia AC - Access Control\)](#)

Actividades requeridas:

1. Identificar y documentar todos los activos críticos (`docs/01-inventario-activos.md`)
2. Crear diagrama de arquitectura con actores y trust boundaries (`diagrams/`)
3. Aplicar STRIDE para identificar amenazas (`docs/03-analisis-stride.md`)
4. Priorizar amenazas con DREAD (`docs/04-priorizacion-dread.md`)
5. Crear matriz de controles de seguridad (`docs/06-plan-mitigacion.md`)
6. Documentar riesgos residuales (`docs/07-riesgos-residuales.md`)

Entregables:

- Documento de análisis de riesgos (basado en `Plantilla_Analisis_Riesgos.md`)
 - Diagrama de arquitectura con trust boundaries
 - Lista de amenazas priorizadas
 - Plan de mitigación
-

Escenario 2: Plataforma de E-Commerce

Asignado: Andres Varela, Pablo Morales y Horacio Duarte

Contexto:

Una tienda online con las siguientes funcionalidades:

- Catálogo de productos con búsqueda
- Carrito de compras y checkout
- Múltiples métodos de pago
- Panel de administración
- Programa de fidelización
- Chat con clientes

Alcance del análisis:

- Frontend React
- Backend Node.js
- Base de datos MongoDB
- Redis para caché
- CDN para assets estáticos
- WebSocket para chat

Plantillas y Enlaces de Ayuda:

- OWASP API Top 10: [API Security 2023](#)
- OWASP E-Commerce: [Guidelines](#)
- Fraud Detection: [MITRE ATT&CK - Impact](#)

Actividades requeridas:

1. Modelar amenazas con STRIDE
2. Identificar attack surfaces
3. Analizar flujos de datos sensibles
4. Evaluar riesgos de integración con procesadores de pago



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

5. Documentar amenazas específicas de e-commerce (fraud detection, inventory manipulation)

Entregables:

- Diagrama de data flow
 - Inventario de amenazas por categoría STRIDE
 - Risk assessment report
 - Recomendaciones de arquitectura
-

Escenario 3: Sistema de Salud - Historias Clínicas Electrónicas

Asignado: Bibiana Fariello, Paola Benedictti

Contexto:

Un hospital implementa un sistema de HCE con:

- Registro de pacientes
- Notas de evolución médica
- Prescripción de medicamentos
- Resultados de laboratorio
- Imágenes médicas (DICOM)
- Portal para pacientes

Alcance del análisis:

- Aplicación web (React)
- API REST + FHIR
- Base de datos MySQL
- PACS para imágenes
- Integración con laboratorio externo

Plantillas y Enlaces de Ayuda:

- **HIPAA / Salud:** [NIST SP 800-66 Rev. 2](#)



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- **Privacidad (URCDP):** [Guía Evaluación de Impacto - Agesic](#)
- **FHIR Security:** [HL7 FHIR Security](#)
- **ISO 27799:** Gestión de seguridad de la información en salud

Actividades requeridas:

1. Identificar activos de alta criticidad (datos de salud = PHI)
2. Cumplir con consideraciones de HIPAA/GDPR
3. Threat modeling para datos médicos
4. Analizar riesgos de interoperabilidad
5. Evaluar controles de acceso a datos sensibles

Entregables:

- Risk assessment conforme a NIST SP 800-66
 - Análisis de compliance (HIPAA, GDPR)
 - Matriz de controles de seguridad
 - Privacy impact assessment
-

Escenario 4: Plataforma de Educación Online (LMS)

Asignado: Nazarena Valiero, Simon Corvo

Contexto:

Una plataforma de e-learning con:

- Cursos en video
- Exámenes y evaluaciones
- Foros de discusión
- Certificados digitales
- Panel de progreso
- Gamificación

Alcance del análisis:



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Frontend Vue.js
- Backend Python/Django
- PostgreSQL
- CDN para video
- Integración con API de certificates

Plantillas y Enlaces de Ayuda:

- **Privacidad de menores (COPPA):** [FTC COPPA](#)
- **Academic Integrity:** [Cheating Detection - OWASP](#)
- **DRM / Content Protection:** [OWASP Content Security Policy](#)

Actividades requeridas:

1. Threat modeling del flujo de certificación
2. Analizar riesgos de cheating en exámenes
3. Evaluar protección de contenido intelectual
4. Identificar amenazas en interacción social (foros)
5. Assessment de privacidad de datos de menores (COPPA)

Entregables:

- Documento de análisis de amenazas
- Evaluación de privacidad
- Controles para integridad académica
- Guía de compliance

Escenario 5: IoT - Sistema de Domótica Smart

Asignado: Renzo Rampoldi, Felipe Queirolo

Contexto:

Sistema de automatización del hogar:

- Control de iluminación



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Termostato inteligente
- Cerraduras electrónicas
- Cámaras de seguridad
- Asistentes de voz
- Sensores de movimiento/temperatura

Alcance del análisis:

- IoT devices (various protocols)
- Hub central
- Aplicación móvil
- Cloud backend
- Integraciones con Alexa/Google Home

Plantillas y Enlaces de Ayuda:

- OWASP IoT Top 10: [OWASP IoT Project](#)
- IoT Attack Surface: [MITRE ATT&CK for ICS](#)
- Protocolos (Zigbee/Z-Wave): [Zigbee Security](#)

Actividades requeridas:

1. Mapear superficie de ataque IoT
2. Analizar protocolos (Zigbee, Z-Wave, WiFi)
3. Threat modeling de dispositivos críticos (cerraduras)
4. Evaluar riesgos de integración con asistentes
5. Analizar amenazas de firmware

Entregables:

- Inventario de activos IoT
 - Análisis de amenazas por dispositivo
 - Evaluación de riesgos de comunicaciones
 - Recomendaciones de seguridad IoT
-

Escenario 6: Sistema de Recursos Humanos (HRIS)

Asignado: Luis Andrada, Leonardo Gimenez

Contexto:

Plataforma de gestión de RRHH:

- Nóminas y liquidaciones
- Gestión de beneficios
- Evaluaciones de desempeño
- Portal de empleados
- Onboarding digital
- Generación de contratos

Alcance del análisis:

- Aplicación web
- Backend Java/Spring
- Integración con sistemas de nómina
- Base de datos Oracle
- Firma digital de documentos

Plantillas y Enlaces de Ayuda:

- OWASP Top 10: [2021 Edition](#)
- Insider Threat: [NIST SP 800-53 \(Familia SI\)](#)
- ISO 27001 (HR Security): [ISO/IEC 27001 A.7](#)

Actividades requeridas:

1. Identificar datos de alta sensibilidad (salarios, beneficios)
2. Threat modeling con STRIDE
3. Analizar riesgos de insider threats
4. Evaluar controles de acceso basados en roles
5. Assessment de continuidad de negocio



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Entregables:

- Risk register
 - Análisis de amenazas internas
 - Controles de acceso documentados
 - Plan de continuidad
-

Escenario 7: API Gateway para Microservicios

Asignado: [Por asignar]

Contexto:

Arquitectura de microservicios con:

- API Gateway central
- Autenticación/Authorization (OAuth2, JWT)
- Service Mesh
- Logging centralizado
- Circuit breakers
- Rate limiting

Alcance del análisis:

- Kong/AWS API Gateway
- Kubernetes cluster
- Multiple microservices (inventory, orders, users)
- Service-to-service communication (mTLS)
- Redis/Message queue

Plantillas y Enlaces de Ayuda:

- OWASP API Security Top 10: [2023 Edition](#)
- Kubernetes Security: [K8s Security Docs](#)
- Service Mesh (Istio): [Istio Security](#)
- Zero Trust: [NIST SP 800-207](#)

Actividades requeridas:

1. Modelar amenazas de arquitectura de microservicios
2. Analizar riesgos de API Gateway
3. Evaluar comunicación entre servicios
4. Threat modeling de service mesh
5. Analizar riesgos de configuración de Kubernetes

Entregables:

- Arquitectura de seguridad documentada
 - Amenazas por componente
 - Controles de seguridad en gateway
 - Kubernetes security assessment
-

Escenario 8: Sistema de Votación Electrónica

Asignado: Francisco Ancheta, Damazo Tor, Diego Koci

Contexto:

Plataforma de votación digital para elecciones organizacionales:

- Registro de votantes
- Autenticación de identidad
- Emisión de voto (anonimato)
- Escrutinio automático
- Resultados en tiempo real
- Auditoría completa

Alcance del análisis:

- Aplicación web/móvil
- Backend con cifrado homomórfico
- Blockchain para audit trail



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Sistema de encriptación de votos

Plantillas y Enlaces de Ayuda:

- OWASP Voting: [Election Security](#)
- Blockchain Security: [MITRE ATT&CK - Blockchain](#)
- Anonimalidad: [RFC 6973 - Privacy Considerations](#)

Actividades requeridas:

1. Análisis de amenazas específico para sistemas de votación
2. Modelar requisitos de seguridad (integridad, anonimalidad, verificabilidad)
3. Threat modeling con enfoque en manipulación de resultados
4. Evaluar riesgos de coerción/voto coercion
5. Análisis de privacidad del votante

Entregables:

- Documento de requisitos de seguridad
- Análisis de amenazas específicas
- Matriz de controles de integridad
- Evaluación de anonimalidad

Escenario 9: Plataforma Ridesharing (Tipo Uber)

Asignado: Ignacio González, Mathias Pessaj, Sebastián Di Loreto

Contexto:

Aplicación tipo Uber con:

- Geolocalización en tiempo real
- Matching conductor-pasajero
- Sistema de pagos integrado
- Ratings y reviews
- Chat in-app



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Historia de viajes

Alcance del análisis:

- App móvil (iOS/Android)
- Backend Node.js
- PostgreSQL + Redis
- Google Maps API
- Stripe/pagos

Plantillas y Enlaces de Ayuda:

- OWASP Mobile Top 10: [Mobile Security](#)
- Geolocation Privacy: [OWASP Location Privacy](#)
- Fraud in Ridesharing: [MITRE ATT&CK - Impact](#)

Actividades requeridas:

1. Threat modeling de datos de ubicación
2. Analizar riesgos de privacidad GPS
3. Evaluar seguridad de pagos
4. Assessment de comunicación en tiempo real
5. Análisis de fraude en transacciones

Entregables:

- Privacy impact assessment (ubicación)
- Análisis de amenazas de geolocalización
- Controles de seguridad en pagos
- Evaluación de fraude

Escenario 10: Industrial Control System (SCADA/ICS)

Asignado: Mateo Sparano, Christian Busquets



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Contexto:

Sistema de control industrial para planta manufacturera:

- Control de procesos productivos
- Monitoring de sensores
- Control de PLCs
- Alertas y alarmas
- Reporting de producción
- Integración con ERP

Alcance del análisis:

- SCADA/HMI
- PLCs (Siemens, Allen Bradley)
- Red industrial (PROFINET, EtherNet/IP)
- Historian server
- Integración con corporate network

Plantillas y Enlaces de Ayuda:

- MITRE ATT&CK for ICS: [ICS Matrix](#)
- NIST SP 800-82: [Guide to ICS Security](#)
- ISA/IEC 62443: [Industrial Automation Security](#)

Actividades requeridas:

1. Análisis de amenazas a entornos OT/ICS
2. Identificar activos críticos de planta
3. Modelar amenazas con enfoque IT/OT
4. Evaluar riesgos de acceso remoto
5. Assessment de segmentación de red

Entregables:

- Risk assessment OT
- Inventario de activos ICS
- Análisis de amenazas IT/OT



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

- Plan de segmentación
- Controles de acceso remoto

Metodologías y Herramientas

Metodologías a Utilizar

Metodología	Uso	Herramientas
STRIDE	Categorización de amenazas	Microsoft TMT , OWASP Threat Dragon
DREAD	Priorización de riesgos	Plantilla propia
MITRE ATT&CK	Tactics y techniques	ATT&CK Navigator
NIST SP 800-30	Análisis de riesgos	Plantilla NIST
ISO 27001	Gestión de riesgos	Frameworks ISO
PASTA	Proceso de threat modeling	Metodología complementaria

Herramientas Recomendadas

Herramienta	Tipo	Descripción	Enlace
OWASP Threat Dragon	Diagramación	Código abierto para threat modeling	threatdragon.org
Microsoft TMT	Desktop app	Threat Modeling Tool	Download
draw.io	Diagramación	Diagramas de arquitectura	app.diagrams.net



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Herramienta	Tipo	Descripción	Enlace
MITRE ATT&CK Navigator	Visualización	Mapeo de amenazas	attack-navigator
Risk Radar	Gestión	Risk register	-
OWASP Risk Rating	Metodología	Plantilla de riesgos	OWASP Guide

Criterios de Evaluación

Criterio	Peso	Descripción
Identificación de activos	15%	Todos los activos críticos documentados
Diagrama de arquitectura	15%	Claro, con trust boundaries
Aplicación de metodología	20%	STRIDE/DREAD correctamente usado
Profundidad del análisis	20%	Amenazas realistas y completas
Plan de mitigación	20%	Controles viables y priorizados
Calidad de documentación	10%	Claro y ordenado

Nota: Si se usó IA, se evaluará también la calidad y organización de los prompts en la carpeta `prompts/`.

Referencias Generales



FACULTAD DE
INGENIERÍA
UDELAR



ANEP
UTU

DIRECCIÓN GENERAL
DE EDUCACIÓN
TÉCNICO PROFESIONAL

Recurso	URL
OWASP Threat Modeling	https://owasp.org/www-community/Threat_Modeling
NIST SP 800-30 Rev. 1	https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublicatio n800-30r1.pdf
NIST SP 800-53 Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/r5/final
MITRE ATT&CK	https://attack.mitre.org/
ISO 27001	https://www.iso.org/isoiec-27001-information-security.html
Agesic - Gestión de Riesgos	https://www.gub.uy/agencia-gobierno-electronico-sociedad-informacion-conocimiento/comunicacion/publicaciones/metodologia-gestion-riesgos-v20
Plantilla Local	Plantilla_Analisis_Riesgos